

**Cyber Risk Governance in Public Sector Organizations: A Case Study of DPMPTSP
Cilacap**

by Fiqki Azizah

**A dissertation submitted in partial fulfilment of the requirements for the degree of
Master of Science (MSc) in Cyber Security**

Computing Department

University of Essex

Supervisor: Prof. Samuel Danso

18 May 2026

Abstract

Cyber risk governance is increasingly critical for public sector organisations that rely on digital systems to deliver services and manage sensitive information. Despite the availability of international standards such as ISO/IEC 27005 and the NIST SP 800 series, many local government institutions face significant challenges in implementing structured cyber risk governance due to organisational and resource constraints. This study examines the state of cyber risk governance within DPMPTSP Cilacap, a local public sector organisation in Indonesia, through a qualitative case study approach.

Data collection was conducted through a semi-structured interview with the organisation's sole IT personnel responsible for cyber-related processes, complemented by a structured review of organisational documents and governance artefacts. A framework-based gap analysis was applied to compare existing practices against ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39. The findings reveal a near-complete absence of formal cyber risk governance mechanisms, including policies, risk registers, continuity plans, and defined accountability structures. Cyber risk management practices were found to be largely informal and reactive, with limited organisational awareness or strategic oversight.

The study contributes to cyber risk governance literature by demonstrating how governance absence itself constitutes a critical organisational risk in resource-constrained public sector contexts. A phased and pragmatic governance improvement roadmap is proposed, focusing on foundational governance capabilities that can be realistically implemented with limited resources.

Chapter 1: Introduction

1.1 Background

The increasing reliance on digital technologies within public sector organisations has significantly expanded the cyber risk landscape. Government institutions routinely process sensitive citizen data, deliver digital public services, and depend on interconnected information systems to fulfil their mandates. As a result, cyber security incidents—such as data breaches, service disruptions, and ransomware attacks—pose not only technical risks but also threats to public trust, legal compliance, and operational continuity.

Cyber risk governance refers to the structures, processes, and responsibilities through which organisations identify, assess, and manage cyber-related risks in a coordinated and accountable manner. International standards and frameworks, including ISO/IEC 27005 and the National Institute of Standards and Technology (NIST) Special Publication 800-30 and 800-39, provide guidance for implementing structured cyber risk management and governance practices. These frameworks emphasise risk identification, evaluation, treatment, and continuous monitoring, integrated with organisational decision-making and accountability structures.

Despite the availability of internationally recognised frameworks, many public sector organisations—particularly in developing and resource-constrained environments—struggle to implement formal cyber risk governance. Common challenges include limited financial resources, lack of specialised expertise, fragmented responsibilities, and insufficient policy direction. In such contexts, cybersecurity is often managed in an informal or reactive manner, addressing incidents only after they occur rather than proactively reducing risk exposure (Norris and Mateczun, 2025; Egwuatu, 2025).

Indonesia's public sector exemplifies these challenges. While national cyber strategies and regulations exist at a high level, their translation into operational governance practices at local government institutions remains inconsistent. This gap between policy intention and practical implementation creates vulnerabilities that may compromise the confidentiality, integrity, and availability of public information systems (Kayode-Ajala, 2023; World Bank, 2025).

This dissertation examines cyber risk governance practices within a local public sector organisation, DPMPTSP Cilacap, through an in-depth case study. The organisation provides public services that rely on information systems but operates within significant organisational and resource constraints. By analysing its current cyber risk governance practices and comparing them against international

standards, this study aims to provide evidence-based insights into governance gaps and propose practical improvement strategies suitable for similar public sector environments.

1.2 Problem Statement

Effective cyber risk governance requires formal policies, defined roles and responsibilities, structured risk assessment processes, and documented governance artefacts. However, preliminary investigation and data collection at DPMPTSP Cilacap indicate the absence of fundamental cyber risk governance components. These include the lack of a formal cyber security policy, risk register, IT or digital strategy, business continuity and disaster recovery plans, and documented governance reporting mechanisms.

Cyber-related issues within the organisation are primarily addressed in a reactive manner, without systematic risk identification, evaluation, or prioritisation. Responsibility for IT and cyber-related processes is concentrated in a single staff member, with limited organisational support, formal authority, or strategic direction. As a result, cyber risks are not consistently communicated to management, nor are they incorporated into broader organisational decision-making processes.

The absence of structured cyber risk governance exposes the organisation to operational disruptions, data security risks, and potential regulatory non-compliance. Moreover, the lack of documented processes and governance artefacts limits organisational learning, accountability, and long-term resilience. Despite these challenges, there is limited empirical research examining how cyber risk governance functions—or fails to function—within local public sector organisations operating under such constraints.

This study addresses this gap by systematically analysing the current state of cyber risk governance at DPMPTSP Cilacap and identifying discrepancies between existing practices and internationally recognised governance frameworks.

1.3 Research Objectives

The primary objective of this research is to evaluate the maturity of cyber risk governance practices within a public sector organisation and identify opportunities for improvement. The specific objectives are to:

1. Assess the current cyber risk governance practices at DPMPTSP Cilacap, including existing policies, processes, and responsibilities.
2. Identify gaps between the organisation's current practices and established international standards, specifically ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39.

3. Examine organisational and human factors influencing the effectiveness of cyber risk governance.
4. Propose a practical governance improvement roadmap tailored to the constraints of a resource-limited public sector environment.

1.4 Research Questions

To achieve the stated objectives, this study seeks to answer the following research questions:

1. What is the current state of cyber risk governance at DPMPTSP Cilacap?
2. To what extent do existing practices align with ISO/IEC 27001, ISO/IEC 27005 and NIST cyber risk governance frameworks?
3. What key governance gaps exist in relation to risk identification, assessment, and management?
4. How can cyber risk governance be pragmatically improved within a resource-constrained public sector organisation?

1.5 Significance of the Study

This study contributes to both academic research and practical governance improvement. From an academic perspective, it extends existing literature on cyber risk governance by providing an in-depth qualitative case study focused on a local public sector institution within a developing country context. It highlights how governance gaps manifest in organisations with limited resources and minimal formal structures.

From a practical perspective, the findings offer actionable insights for policymakers, public sector managers, and IT practitioners seeking to strengthen cyber risk governance under similar constraints. The proposed governance roadmap emphasises foundational capabilities that can be realistically implemented without extensive financial or technical resources, thereby supporting incremental and sustainable improvement.

1.6 Scope and Limitations

This research focuses on a single public sector organisation, DPMPTSP Cilacap, and adopts a qualitative case study approach. Data collection is limited to interviews with the organisation's IT personnel and the review of available organisational documentation. While the findings may not be statistically generalisable, they provide analytically transferable insights relevant to similar public sector organisations facing comparable challenges.

Cyber risk governance is examined at the organisational level rather than through detailed technical security controls. The study does not assess system-level

vulnerabilities or perform penetration testing, as its primary focus is governance structures, processes, and decision-making mechanisms.

1.7 Structure of the Dissertation

This dissertation is structured as follows. Chapter 1 introduces the research background, problem statement, objectives, and research questions. Chapter 2 reviews relevant literature on cyber risk management and governance frameworks, including ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39 standards. Chapter 3 outlines the research methodology, data collection methods, and analytical approach. Chapter 4 presents the findings of the case study and the results of the gap analysis. Chapter 5 discusses the findings in relation to existing literature and proposes a governance improvement roadmap. Chapter 6 concludes the study by summarising key contributions, limitations, and directions for future research.

Chapter 2: Literature Review

2.1 Introduction

This chapter reviews academic and professional literature related to cyber risk governance, with particular focus on public sector organisations operating in resource-constrained environments. It examines foundational concepts of risk and governance, established cyber risk management frameworks, governance models, and organisational and human factors influencing governance effectiveness. The chapter concludes by identifying gaps in existing literature that this study seeks to address through a qualitative case study approach.

2.2 Risk and Cyber Risk Governance

Risk is generally defined as the possibility that an event or action will negatively affect organisational objectives. Contemporary research emphasises that risk is not solely technical but also socio-organisational, requiring structured governance mechanisms to ensure accountability and effective decision-making. Cyber risk governance, therefore, extends beyond technical controls to encompass organisational structures, policies, and strategic oversight mechanisms (ISACA, 2024; Magnusson et al., 2025).

Recent developments in cybersecurity frameworks further highlight the importance of governance. For instance, the NIST Cybersecurity Framework 2.0 elevates governance as a central function guiding all other cybersecurity activities, reinforcing the need for strategic alignment between risk management and organisational objectives (ISACA, 2024).

In public sector organisations, cyber risk governance is particularly complex due to bureaucratic structures, competing priorities, and regulatory obligations. These organisations manage highly sensitive data and critical services, meaning governance failures can significantly impact public trust and service continuity (KPMG, 2024).

2.3 Cyber Risk Management Frameworks

2.3.1 ISO/IEC 27005

ISO/IEC 27005 provides guidance on information security risk management within the context of an information security management system (ISMS). The standard outlines a structured process consisting of context establishment, risk identification, risk analysis, risk evaluation, risk treatment, communication, and monitoring. ISO 27005 emphasises alignment between risk management activities and organisational objectives, promoting a continuous and iterative approach.

A key strength of ISO 27005 lies in its flexibility, allowing organisations to tailor risk management processes according to their size, complexity, and risk appetite. However, several studies have noted that successful implementation requires a baseline level of organisational maturity, including documented policies, defined roles, and management commitment. In resource-constrained environments, such prerequisites are often absent, limiting the applicability of the framework without adaptation.

2.3.2 NIST SP 800-39

NIST Special Publication 800-39 provides guidance on managing information security risk at organisational, mission, and system levels. The framework introduces a multi-tier governance perspective, linking organisational governance (Tier 1), mission and business processes (Tier 2), and information systems (Tier 3). This integrated structure supports a coordinated approach to risk management, ensuring alignment between strategic objectives, operational processes, and technical controls.

NIST SP 800-39 places strong emphasis on governance integration, risk communication, and management accountability, making it particularly relevant for evaluating cyber risk governance maturity. The framework highlights the importance of aligning risk management activities with organisational objectives and embedding governance practices into decision-making processes.

However, similar to ISO/IEC 27005, NIST SP 800-39 assumes the presence of structured processes, defined roles, and sufficient organisational capability. Public sector organisations with limited staffing, expertise, and formal governance structures may face challenges in fully adopting these principles, necessitating simplified and incremental implementation approaches.

Despite its comprehensive governance perspective, the practical implementation of NIST SP 800-39 can be constrained by organisational limitations. Research indicates that such frameworks require sufficient maturity, resources, and continuous monitoring capabilities, which are often lacking in resource-constrained public sector environments (Folorunso et al., 2024).

Moreover, public sector organisations frequently struggle to implement key governance elements such as risk metrics, performance indicators, and continuous assessment processes, limiting the effectiveness of governance frameworks in practice (Magnusson et al., 2025).

2.4 Governance Models and Approaches

Risk governance literature distinguishes between different governance models based on how expertise, decision-making, and transparency are distributed. Millstone et al. (2004) describe three primary models: technocratic, decisionistic, and transparent governance.

Technocratic models rely heavily on expert judgement and technical specialists, often excluding non-technical stakeholders from decision-making. Decisionistic models place authority with senior management or political actors, with experts serving in advisory roles. Transparent governance models emphasise openness, stakeholder participation, and clear communication of risks and decisions.

In the context of cyber risk governance, public sector organisations often default to technocratic models due to limited cyber expertise among senior management. While this can enable faster technical responses, it may also result in poor strategic alignment and weak accountability. Literature increasingly advocates for transparent and integrated governance models that elevate cyber risk to organisational leadership while maintaining technical input.

The International Risk Governance Council (IRGC) framework supports this view by promoting risk governance as a multi-actor process involving assessment, management, and communication. This perspective is particularly relevant for public institutions, where accountability to citizens and oversight bodies is critical.

2.5 Human and Organisational Factors

Human and organisational factors play a central role in cyber risk governance effectiveness. Security culture, defined as shared values, beliefs, and practices related to information security, influences how employees perceive and respond to cyber risks. Studies by Sasse and Flechais highlight that security failures often stem from organisational issues rather than technical deficiencies.

Risk perception also affects governance outcomes. Slovic's work on risk perception demonstrates that individuals may underestimate low-frequency, high-impact risks, such as cyber incidents, particularly in the absence of previous experience. In resource-constrained organisations, limited awareness and training further exacerbate this issue, leading to reactive rather than proactive risk management.

Accountability mechanisms are equally important. Dekker's concept of a "just culture" emphasises learning and responsibility without blame, encouraging reporting and continuous improvement. In organisations lacking formal role definitions and policies, accountability for cyber risk is often unclear, reducing incentives for structured governance practices.

2.6 Cyber Risk Governance in the Public Sector

Existing literature increasingly highlights systemic challenges in implementing cyber risk governance within public sector organisations. These challenges are particularly pronounced at the local government level, where limited resources, lack of expertise, and decentralised structures constrain effective implementation (Hossain et al., 2024).

A recent systematic review by Hossain et al. (2024) demonstrates that cybersecurity research in local government contexts remains fragmented, with limited institutional capacity to address emerging cyber threats. Local governments must balance digital transformation with security responsibilities, often without adequate governance frameworks or resources.

Empirical studies further show that local governments consistently underperform in cybersecurity practices. Research indicates that many municipalities face structural challenges, including limited financial resources, lack of dedicated cybersecurity expertise, and weak policy implementation, which collectively hinder effective risk management (Hossain et al., 2025; Norris and Mateczun, 2025). Additionally, evidence suggests that local authorities often fail to adopt or fully implement recommended cybersecurity policies, contributing to fragmented governance and increased vulnerability to cyber threats (Norris and Mateczun, 2023).

These findings suggest that governance weaknesses, rather than purely technical failures, are a primary driver of cybersecurity vulnerabilities in the public sector.

2.6.1 Developing Countries Context

Cyber risk governance challenges are further intensified in developing country contexts, where institutional, financial, and human resource constraints are more severe. Rapid digitalisation has increased exposure to cyber threats without equivalent investment in governance frameworks or cybersecurity capacity (Kayode-Ajala, 2023).

Developing countries often lack foundational cybersecurity infrastructure, including regulatory enforcement mechanisms, skilled personnel, and incident response capabilities. The absence of such capabilities reduces organisational resilience and limits the ability to effectively manage cyber risks (World Bank, 2025).

Research also shows that organisations in developing economies tend to rely on ad-hoc cybersecurity practices, with minimal formal risk assessment, insufficient training, and a lack of structured governance processes (Egwuatu, 2025). Furthermore, the adoption of cybersecurity practices is influenced by external factors such as regulatory frameworks, institutional capacity, and financial

resources, which are often underdeveloped or inconsistent in these contexts, limiting the effectiveness of cybersecurity implementation (Kayode-Ajala, 2023)

These findings highlight the importance of developing context-sensitive governance approaches rather than directly applying international frameworks without adaptation.

2.7 Summary and Research Gap

This chapter has reviewed key literature on cyber risk governance, risk management frameworks, governance models, and organisational factors affecting governance effectiveness. While standards such as ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39 provide comprehensive guidance, their practical application in resource-constrained public sector organisations remains challenging.

Existing research offers limited insight into how local public institutions manage cyber risk in the absence of formal frameworks and documentation. Moreover, the role of organisational constraints, informal practices, and concentrated responsibilities is under-explored. This study addresses these gaps by conducting a qualitative case study of cyber risk governance within a local public sector organisation, using a document-based and interview-validated gap analysis to assess governance maturity and propose realistic improvement strategies.

Chapter 3: Research Methodology

3.1 Introduction

This chapter describes the research methodology adopted to investigate cyber risk governance practices within a public sector organisation. It outlines the research design and approach, case study selection, data collection methods, analytical techniques, and ethical considerations. The chosen methodology aligns with the exploratory nature of the study and supports an in-depth examination of governance practices within a real-world organisational context.

3.2 Research Design and Approach

This research adopts a qualitative single-case study approach to examine cyber risk governance practices within a public sector organisation. The case study design enables an in-depth exploration of organisational processes, governance structures, and contextual constraints, which are critical in understanding how cyber risk governance is implemented—or absent—in real-world settings.

The research is further underpinned by a framework-based evaluative approach, where the organisation's current practices are assessed against internationally recognised cyber risk governance frameworks, specifically ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39. These frameworks were selected due to their complementary perspectives on information security management, risk processes, and governance integration.

ISO/IEC 27001 provides a structured model for establishing an Information Security Management System (ISMS), particularly in relation to governance structures, policies, and roles and responsibilities. ISO/IEC 27005 focuses specifically on information security risk management processes, including risk identification, analysis, evaluation, and treatment. NIST SP 800-39 extends this perspective by introducing a governance-oriented approach, linking organisational, mission, and system-level risk management through a multi-level structure.

Together, these frameworks establish a unified benchmark for assessing governance maturity, allowing for a structured comparison between existing organisational practices and internationally recognised best practices.

The use of a unified benchmark is particularly important in this study, as DPMPTSP does not operate with formal governance documentation or structured processes. By mapping organisational practices against these frameworks, it is possible to systematically identify governance gaps and evaluate the extent to which foundational components—such as risk identification, assessment, treatment, and monitoring—are present or absent.

Beyond assessment, the research adopts a design-oriented approach, whereby the identified gaps are translated into practical governance artefacts. These artefacts—including a cyber risk governance roadmap, incident response flow, cyber risk register, and governance checklist—represent operational outputs derived directly from the framework-based analysis. Rather than recommending full framework adoption, the artefacts provide simplified and context-adapted mechanisms that address specific governance deficiencies while remaining feasible within the organisation's constraints.

The overall research methodology adopted in this study is illustrated in Figure 1. The diagram provides a conceptual overview of the research process, beginning with data collection and framework benchmarking, followed by gap analysis, artefact development, and iterative evaluation. This structured approach ensures that the proposed governance improvements are both theoretically grounded and practically validated within the organisational context.

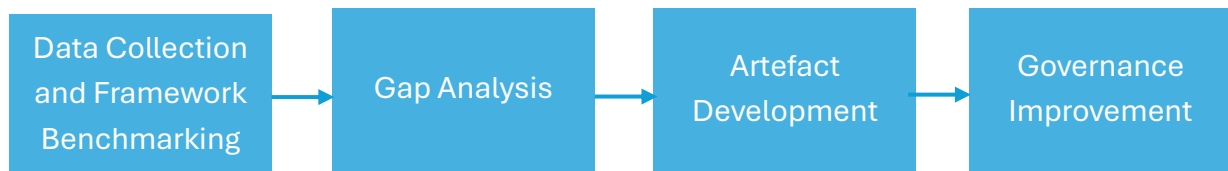


Figure 1. Overall research Methodology

Each stage of the methodology is designed to systematically transition from understanding the current organisational context (AS-IS) to developing practical governance improvements (TO-BE state).

This structured approach ensures that the artefacts are not developed in isolation, but are instead grounded in recognised standards and directly aligned with the governance gaps identified within the organisation.

3.3 Evaluation of Developed Artefacts

To ensure the practical relevance and applicability of the developed artefacts, an iterative evaluation process was conducted in collaboration with the organisation.

The evaluation was carried out through:

- Video-based discussions (Microsoft Teams calls), allowing direct interaction with the IT personnel to review artefacts and gather feedback
- Demonstrations of artefacts, where the purpose, structure, and usage of each artefact were explained and discussed
- Document exchange via Google Drive and email, enabling collaborative review, refinement, and validation of artefacts

This evaluation approach allowed the researcher to validate whether the artefacts:

- Are understandable and usable within the organisational context
- Align with existing practices and workflows
- Address the identified governance gaps effectively
- Are feasible given resource and capability constraints

The feedback obtained from these interactions informed the refinement of artefacts and provided valuable insight into practical implementation challenges, such as limited resources, lack of technical expertise, and organisational constraints.

While ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39 are used as a unified benchmark in this study, their roles differ within the analysis and artefact development process. ISO/IEC 27001 primarily informs organisational governance structures, including policy frameworks, roles, and control domains, while ISO/IEC 27005 supports the risk management process, particularly in relation to risk identification, analysis, and treatment. NIST SP 800-39 provides a governance-oriented perspective, linking cyber risk management across organisational levels.

As a result, the developed artefacts emphasise governance and practical implementation, aligning more closely with ISO/IEC 27001 governance elements and NIST SP 800-39, rather than full framework implementation or comprehensive compliance.

This iterative design and evaluation process strengthens the methodological rigor of the study by ensuring that the proposed governance improvements are both theoretically grounded and practically validated.

3.4 Case Study Context

The case study focuses on DPMPTSP Cilacap, a local public sector organisation responsible for delivering public services that rely on information systems. Like many local government institutions, the organisation operates under budgetary and staffing constraints, with limited access to specialised cyber security expertise.

Responsibility for information technology and cyber-related functions is concentrated in a single IT personnel. This organisational structure influenced both the research design and data collection strategy, as it reflects the operational reality of cyber risk governance within the institution.

3.5 Data Collection Methods

Data collection was conducted using a combination of semi-structured interviews and document review. This multi-method approach enabled triangulation of findings and enhanced the credibility of the results.

3.5.1 Semi-Structured Interview

A semi-structured interview was conducted with the IT personnel responsible for IT and cyber-related processes within the organisation. This individual was selected as the key informant due to their direct involvement in system management, incident handling, and informal decision-making related to cyber issues.

The interview format allowed flexibility to explore governance practices, perceived risks, constraints, and organisational culture, while maintaining a consistent structure aligned with the research objectives. Topics covered included:

- Existing cyber security practices and controls
- Risk identification and incident handling processes
- Roles and responsibilities related to cyber risk
- Awareness and training practices
- Resource, budgetary, and organisational constraints

The decision not to employ surveys was justified by the organisational structure, as no wider population with cyber risk management or governance responsibilities existed. Consequently, a survey would not have provided meaningful or valid data.

3.5.2 Document Review and Artefact Analysis

A structured document review was performed to identify existing governance artefacts and supporting documentation. The review focused on the presence or absence of formal materials commonly associated with cyber risk governance, including:

- Cyber security or information security policies
- Risk registers and risk assessment records
- IT or digital strategies
- Business Continuity Plans (BCP) and Disaster Recovery Plans (DRP)
- Audit reports related to IT or cyber security
- Governance or management reporting related to cyber risk

The review confirmed the absence of many core governance artefacts. These absences were treated as empirical findings, rather than as limitations of the research, and were validated through interview data.

3.6 Data Analysis Approach

3.6.1 Gap Analysis

The primary analytical method employed in this study is gap analysis. This approach involves comparing the organisation's current cyber risk governance practices with recognised international standards to identify areas of misalignment or deficiency.

The analysis was structured around the following frameworks:

- ISO/IEC 27001, providing a governance framework for organisational structures, policies, and control domains
- ISO/IEC 27005, with emphasis on risk context establishment, identification, analysis, evaluation, and treatment
- NIST SP 800-39, emphasising governance integration across organisational, mission, and system levels

Data from interviews and document review were mapped against key governance components derived from these frameworks.

3.6.2 Maturity Assessment

To support clarity and comparability, a simple three-level governance maturity scale was applied:

- 0 – Non-existent: No evidence of formal processes, policies, or governance mechanisms
- 1 – Ad-hoc: Informal or inconsistent practices without documentation or standardisation
- 2 – Defined: Documented and repeatable processes with assigned responsibilities

This simplified scale was selected to reflect the organisation's context and to avoid overstating maturity in the absence of formal governance structures.

3.6.3 Interview Validation

Interview data were used to validate findings from the document review and to provide contextual explanations for identified gaps. This ensured that conclusions were grounded in both observed evidence and practitioner insight, reducing the risk of misinterpretation.

3.7 Ethical Considerations

Ethical principles were adhered to throughout the research process. Informed consent was obtained from the interview participant prior to data collection. Participation was voluntary, and the purpose of the study was clearly explained.

To protect confidentiality, the identity of individual participants has been anonymised. Sensitive operational details that could expose security weaknesses were deliberately excluded from the analysis and reporting. All research data were stored securely and restricted to academic use only.

3.8 Reliability and Validity

To enhance the credibility and trustworthiness of the findings, several measures were adopted:

- Data triangulation through interviews and document review
- Framework-based analysis, grounding findings in established standards
- Transparency of methodology, enabling replication or analytical transferability

While the findings are not statistically generalisable due to the single-case design, they offer analytically transferable insights relevant to similar public sector organisations facing comparable constraints.

3.9 Limitations of the Methodology

This study is limited to a single public sector organisation and relies on one primary informant. While this reflects the organisational reality, it may limit the range of perspectives captured. Additionally, the absence of formal documentation restricts analysis to governance structures rather than technical effectiveness.

However, these limitations are inherent to the research context and are also central to the study's contribution, as they highlight governance challenges commonly faced by resource-constrained public sector institutions.

3.10 Chapter Summary

This chapter has outlined the qualitative case study methodology used to assess cyber risk governance practices at DPMPSTSP Cilacap. Through interviews, document review, and framework-based gap analysis, the study establishes a rigorous and contextually appropriate approach for evaluating governance maturity. The next chapter presents the empirical findings and discusses the identified governance gaps in detail.

Chapter 4: Findings and Gap Analysis

4.1 Introduction

This chapter presents the findings of the qualitative case study examining cyber risk governance practices at DPMPTSP Cilacap. The findings are derived from semi-structured interview data and a structured review of organisational artefacts. A framework-based gap analysis is employed to compare the organisation's current practices against recognised international standards, namely ISO/IEC 27005 and NIST SP 800-39, supported by governance principles derived from ISO/IEC 27001.

The analysis focuses on the current state of governance, including the presence or absence of formal structures, processes, and accountability mechanisms. Where governance artefacts are absent, these omissions are treated as empirical findings indicative of governance maturity.

4.2 Overview of Data Collected

Two primary sources of data informed the findings:

1. Semi-structured interview with the sole IT personnel responsible for IT and cyber-related processes.
2. Document review and artefact analysis, focusing on governance-related documents and evidence.

The triangulation of these sources enabled validation of observed practices and confirmation of governance gaps.

4.3 Current State of Cyber Risk Governance

4.3.1 Governance Structure and Accountability

The findings indicate that cyber risk governance responsibilities at DPMPTSP Cilacap are highly centralised. Responsibility for IT operations, cyber security issues, and incident handling is concentrated in a single staff member. There are no formally defined roles or responsibilities for cyber risk governance at the managerial or organisational level.

Interview data revealed that decisions related to cyber security are primarily operational rather than strategic. There is no formal mechanism for escalating cyber risks to senior management, nor is cyber risk explicitly discussed within broader organisational governance or performance reporting structures.

This structure reflects a technocratic and informal governance model, where technical expertise substitutes for formal governance mechanisms, resulting in limited oversight and accountability.

4.3.2 Policies, Strategies, and Formal Documentation

The document review confirmed the absence of several core governance artefacts commonly associated with cyber risk management:

- No documented cyber security or information security policy
- No IT or digital strategy
- No documented governance framework for cyber risk management

These findings were validated through interview responses, which confirmed that no formal policies or strategic documents guide cyber security decision-making. Instead, practices rely on informal knowledge and individual experience.

The absence of documented policies limits consistency, accountability, and organisational learning, and makes governance practices highly dependent on individual staff continuity.

4.3.3 Risk Identification and Risk Register

The organisation does not maintain a formal risk register or centralised record of cyber risks. There is no systematic process for identifying, documenting, or prioritising cyber risks based on likelihood and impact.

Interview data indicated that risks are recognised informally, often only after incidents or operational disruptions occur. Threat identification is not supported by formal risk assessments, vulnerability analysis, or structured threat modelling.

As a result, cyber risks are neither prioritised nor explicitly linked to organisational objectives, exposing the institution to unmanaged and potentially systemic risks.

4.3.4 Risk Assessment and Treatment Practices

Consistent with the absence of a risk register, formal risk assessment activities are not conducted. There is no documented process for evaluating risks or determining appropriate risk treatment options such as mitigation, transfer, acceptance, or avoidance.

Risk treatment actions are reactive and largely technical in nature, focusing on immediate issue resolution rather than long-term risk reduction. There is no monitoring of residual risk or evaluation of the effectiveness of implemented controls.

This approach reflects a reactive risk posture, with limited capacity for anticipatory or preventative governance.

4.3.5 Monitoring, Review, and Continuous Improvement

The findings show no evidence of continuous monitoring, vulnerability scanning, or periodic review of cyber risks. There is no formal schedule for risk reassessment, policy review, or governance evaluation.

Interview responses confirmed that cyber-related activities are triggered by incidents rather than by structured monitoring or proactive review. Additionally, there are no metrics or key performance indicators used to measure cyber risk governance effectiveness.

This lack of monitoring further reinforces the organisation's limited governance maturity and reduces its ability to adapt to evolving cyber threats.

4.3.6 Business Continuity and Incident Response

The document review confirmed the absence of:

- A Business Continuity Plan (BCP)
- A Disaster Recovery Plan (DRP)
- Formal incident response procedures

Interview data revealed that incident handling relies on improvisation and individual judgement. There is no predefined escalation path, incident classification scheme, or post-incident review process.

The absence of continuity planning poses significant operational risks, particularly in the event of major cyber incidents affecting service availability or data integrity.

4.3.7 Awareness and Training

No formal cyber security awareness or training programme exists within the organisation. Employees are not trained in recognising cyber threats, reporting incidents, or understanding their responsibilities related to information security.

Interview findings indicated limited staff awareness of cyber risks and no structured communication related to cyber governance. This further weakens the organisation's risk posture and increases reliance on technical controls alone.

4.4 Gap Analysis Against International Frameworks

Based on the findings, a gap analysis was performed against key governance components derived from ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39. A simplified maturity scale was applied, as described in Chapter 3.

The results of the gap analysis are summarised in Table 4.1, highlighting key governance areas, their current state, and identified gaps in relation to internationally recognised frameworks.

Table 4.1 Cyber Risk Governance Gap Analysis

Domain	Governance Area	Current State	Gap Identified	Framework Reference
Governance & Leadership	Roles & responsibilities	Partial	No formal cyber risk ownership	ISO 27001 / NIST SP 800-39
Governance & Leadership	Risk reporting	No	No reporting to management	NIST SP 800-39
Risk Management	Risk register	Partial	Limited coverage of cyber risks	ISO 27005
Risk Management	Risk assessment	No	No structured assessment process	ISO 27005
Policies & Procedures	Cyber security policy	No	No formal policy or SOP	ISO 27001
Incident Management	Incident response	No	Informal handling, no documentation	ISO 27005 / NIST SP 800-39
Monitoring	Risk monitoring	No	No continuous monitoring	NIST SP 800-39
Awareness	Security awareness	Partial	Not structured or periodic	ISO 27001
Business Continuity	BCP / DRP	No	No continuity planning	ISO 27001

The analysis indicates that the majority of governance elements are either absent or only partially implemented, confirming a low level of cyber risk governance maturity within the organisation. A detailed version of the governance checklist and full gap mapping is provided in **Appendix A**.

4.5 Summary of Key Findings

The findings indicate that cyber risk governance at DPMPTSP Cilacap is characterised by:

- Absence of formal governance artefacts and policies
- Highly centralised and informal responsibility structures
- Reactive rather than proactive risk management practices
- Limited organisational awareness and accountability

When benchmarked against ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39 standards, the organisation demonstrates a governance maturity level predominantly categorised as non-existent, with some limited ad-hoc practices.

4.6 Artefact Development and Gap Closure Approach

4.6.1 Identified Governance Gaps

The gap analysis in Section 4.4 identified that cyber risk governance at DPMPTSP is characterised by the absence of formal governance structures, processes, and artefacts. Key gaps include:

- Lack of formally defined roles and accountability for cyber risk
- Absence of documented policies and governance frameworks
- No structured risk identification, assessment, or prioritisation processes
- Absence of incident documentation and escalation procedures
- Limited organisational awareness and training
- No monitoring, reporting, or continuous improvement mechanisms

These findings demonstrate that cyber risk governance is largely informal, reactive, and dependent on individual knowledge, creating systemic organisational risk.

4.6.2 Gap Closure Strategy through Artefact Development

To address these gaps, this study adopts a pragmatic, artefact-driven approach rather than direct implementation of ISO/IEC 27001, ISO/IEC 27005 or NIST SP 800-39.

This approach focuses on:

- Translating framework requirements into lightweight and usable artefacts
- Ensuring alignment with existing organisational practices
- Designing solutions that are feasible within resource constraints
- Supporting incremental governance maturity improvement

Each artefact developed represents a practical interpretation of governance principles, tailored to the organisation's operational realities.

4.7 Developed Artefacts and Their Application

4.7.1 Cyber Risk Governance Roadmap

A phased Cyber Risk Governance Roadmap was developed to guide structured improvement.

The roadmap includes:

- Phase 1 (0–6 months): Establish governance foundation (roles, risk register, incident handling, initial awareness activity). At this stage, particular emphasis is placed on the socialisation of incident handling and escalation processes through simple awareness sessions and practical demonstrations. This approach is intended to build organisational understanding, encourage

behavioural change, and support early adoption of governance practices within a resource-constrained environment.

- Phase 2 (6–18 months): Formalise processes and documentation
- Phase 3 (18–36 months): Integrate governance into organisational decision-making

Figure 2 presents the phased Cyber Risk Governance Roadmap, outlining the progression from foundational governance practices to integrated organisational governance.

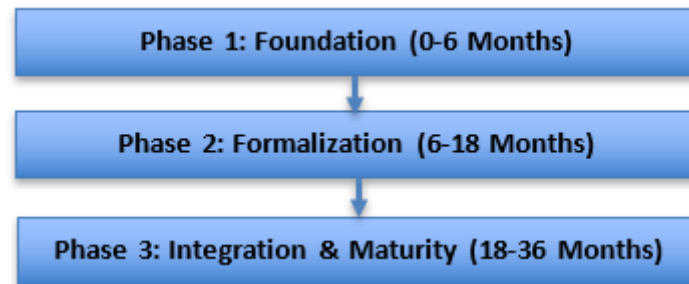


Figure 2 Cyber Risk Governance Roadmap

A detailed version of the Cyber Risk Governance Roadmap artefact is provided in **Appendix B**.

The roadmap prioritises:

- Governance and documentation before technical implementation
- Incremental improvement over full framework adoption
- Alignment with ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39 principles

Application:

- Acts as a strategic implementation guide
- Supports management decision-making and prioritisation
- Enables measurable governance maturity progression

4.7.2 Incident Response and Escalation Flow

An Incident Response Flow (AS-IS and TO-BE model) was developed to formalise current informal practices. Figure 3 illustrates the a more structured approach. The proposed model introduces basic documentation and escalation mechanisms while remaining aligned with existing organisational practices.

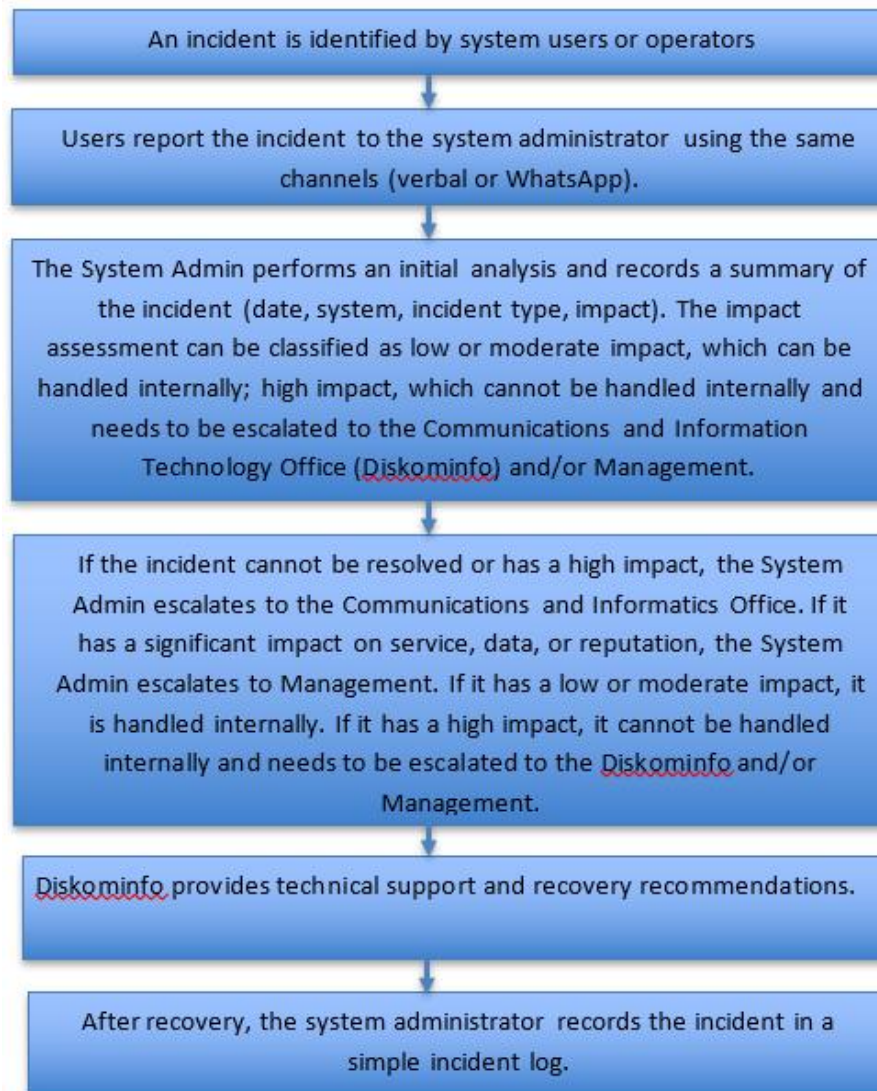


Figure 3 To-Be Incident response and escalation process

Application:

- Enables incident traceability and learning
- Supports coordination with external stakeholders

A detailed version of the incident response and escalation flow is provided in **Appendix C**.

4.7.3 Cyber Risk Register (Top 10 Risks)

A Top 10 Cyber Risk Register was developed as a core governance artefact to formalise risk identification and prioritisation. The register includes:

- Risk ID, asset/process, threat source, vulnerability
- Qualitative risk assessment (Impact × Likelihood)
- Risk owners, controls, and action plans
- Status tracking and review cycles

Example Identified High Risks

Risk ID	Risk Description	Impact	Likelihood	Risk Level
R-001	Unauthorized access (data breach)	High	Medium	High
R-002	Website disruption (DDoS)	Medium	Medium	Medium
R-003	Phishing attack	High	High	High
R-004	Malware infection	High	Medium	High
R-005	Data loss (backup failure)	High	Medium	High

Table 4.2 Sample of identified cyber risks

The register follows a qualitative scoring model, where risk = impact × likelihood, ensuring simplicity and usability for non-technical stakeholders. A full version of the cyber risk register, including risk ownership, controls, and mitigation actions, is provided in **Appendix D**.

Application:

- Provides visibility of cyber risks to management
- Enables prioritisation of mitigation actions
- Supports risk-informed decision-making
- Acts as a living document for continuous governance

4.7.4 Governance Checklist for Assessment (Framework Mapping Tool)

A Governance Checklist was developed as a structured assessment instrument to evaluate the current state of cyber risk governance at DPMPTSP. The checklist maps existing organisational practices against internationally recognised frameworks, specifically:

- ISO/IEC 27001
- ISO/IEC 27005
- NIST SP 800-39

This mapping enables a systematic comparison between the organisation's current practices and established governance requirements, forming a unified benchmark for assessment.

While the governance checklist is aligned with ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39, it does not aim to provide exhaustive coverage of all framework components. Instead, the checklist selectively maps key governance elements that are most relevant to the organisation's current context and maturity level.

This selective mapping approach is intentionally adopted to ensure usability and practical applicability within a resource-constrained environment. Comprehensive implementation of all framework requirements would introduce unnecessary complexity and may not be feasible given the organisation's limited capabilities and resources.

As a result, the checklist functions as a simplified and context-adapted instrument, prioritising core governance capabilities—such as risk identification, incident management, and accountability—rather than full framework compliance. This approach aligns with existing literature, which suggests that organisations with low governance maturity should adopt incremental and context-sensitive implementation strategies rather than attempting full framework adoption.

However, a limitation of this approach is that certain detailed controls and advanced governance elements are not explicitly covered, which may restrict alignment with full ISO/NIST compliance in the long term.

The checklist applies a qualitative scoring approach (Yes / Partial / No) to assess the presence and maturity of governance elements. For each checklist item, the tool captures:

- Existing evidence of implementation
- Identified gaps or weaknesses
- Observations on governance maturity

This structured approach supports a consistent evaluation of governance practices across key domains, including governance and leadership, risk management, incident management, and awareness. Below is the governance checklist summary:

Domain	Example Assessment Area	Status
Governance & Leadership	Roles & responsibilities	Partial
Risk Management	Risk assessment process	Partial
Policies & Procedures	Cyber security policy	No
Incident Management	Incident response procedure	No
Awareness	Security training	Partial
Monitoring	Risk monitoring	No

Table 4.3: Governance Checklist Summary

The full governance checklist, including detailed framework mapping and evidence, is provided in **Appendix A**.

Key Findings from the Checklist Assessment

The application of the checklist revealed several important insights regarding the organisation’s governance maturity:

- The majority of controls were assessed as “Partial” or “No”, indicating a generally low level of governance maturity
- Existing practices were found to be informal and inconsistently applied, with limited documentation

- Significant gaps were identified in areas such as cyber security policy, incident management processes, monitoring, and awareness activities

These findings confirm that cyber risk governance within the organisation is largely reactive and lacks structured implementation.

Application of the Checklist in This Study

Within the context of this research, the governance checklist serves as a diagnostic and analytical tool, supporting the identification of governance gaps and informing the development of artefacts.

Specifically, the checklist was used to:

- Provide a structured method for assessing governance maturity
- Identify priority areas for improvement
- Support the framework-based gap analysis
- Inform the design of practical governance artefacts aligned with identified needs

By grounding the analysis in recognised frameworks, the checklist ensures that the findings are systematic, comparable to established best practices, and adaptable to the organisational context.

4.7.5 Governance Checklist as Artefact

Domain	Checklist Item	Status	Evidence / Notes
Governance & Leadership	Defined roles and responsibilities	Partial	IT role exists, not formalised
Risk Management	Risk assessment procedure	Partial	Informal practices observed
Policies & Procedures	Cyber security policy	No	Not yet implemented
Incident Management	Incident response process	Partial	Informal escalation exists

Table 4.4 Governance Checklist Tool Structure (Example)

A governance checklist artefact was developed in Excel format to enable the organisation to systematically assess its cyber risk governance maturity. The checklist maps organisational practices against ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39, and includes structured fields for recording evidence, identifying gaps, and documenting observations. Each checklist item is evaluated using a simple qualitative scale (Yes / Partial / No), allowing the organisation to determine whether governance controls are fully implemented, partially implemented, or absent. Refer to the table 4.4 for the example of the governance checklist tool structure.

This structured approach supports consistent assessment and provides clear visibility of governance gaps. In addition to its diagnostic function, the checklist

serves as a practical governance tool that supports periodic reassessment and continuous improvement. The inclusion of a simple scoring mechanism enables the organisation to track progress over time and monitor changes in governance maturity.

A full version of the governance checklist tool, including detailed framework mapping, scoring mechanism, and dashboard features, is provided in Appendix E.

The governance checklist was enhanced by introducing a maturity scoring mechanism to enable quantitative assessment of governance maturity. Each checklist item is assigned a score based on its implementation status (Yes = 2, Partial = 1, No = 0), allowing the organisation to calculate an overall maturity level and track improvements over time.

The scoring mechanism is embedded within the tool, enabling simple calculation of a maturity percentage and supporting periodic self-assessment. This ensures that the checklist functions not only as a diagnostic tool, but also as a practical mechanism for continuous governance improvement.

A dashboard sheet was incorporated to automatically calculate key indicators, including the proportion of implemented controls and overall governance maturity percentage. This enhancement transforms the checklist from a static assessment tool into a dynamic governance monitoring instrument.

The governance checklist developed for DPMPTSP is not only intended as an assessment tool, but also functions as a practical mechanism to support the organisation's transition from its current governance state to a more structured and mature state.

By mapping existing practices against ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39, the checklist enables the organisation to systematically identify gaps and prioritise improvement actions. This structured approach provides clear visibility of "what is currently in place" and "what needs to be improved," allowing stakeholders to take targeted and incremental steps toward enhanced governance maturity.

In contrast to comprehensive frameworks—which may be complex and difficult to implement in full within a resource-constrained environment—the checklist offers a simplified and actionable pathway for improvement. It allows the organisation to move progressively from an informal and reactive governance model ("point A") toward a more defined, documented, and consistent governance approach ("point B").

Furthermore, the inclusion of scoring and dashboard features enhances its practical value by enabling the organisation to measure progress over time. This transforms the checklist into a dynamic governance management tool, supporting not only assessment but also continuous monitoring and improvement.

4.8 Client Feedback and Implementation Constraints

4.8.1 Resource Constraints

Client feedback highlights that the organisation faces significant resource constraints, including:

- Limited budget for implementing full ISO/NIST controls
- Limited IT personnel
- No dedicated cybersecurity roles

As a result, full framework adoption is not currently feasible.

4.8.2 Skills and Capability Gaps

The organisation identified key capability challenges:

- Need to upskill existing system administrators
- Limited cybersecurity expertise and technical capability
- Lack of knowledge in risk management and governance practices

Operationally, administrators work in silos, managing individual systems without cross-functional coordination.

4.8.3 Lack of Awareness and Communication

The organisation lacks structured awareness practices:

- No periodic cybersecurity awareness programmes
- No regular communication on cyber risks
- Limited collaboration between administrators

This contributes to:

- Low risk awareness
- Reactive incident handling
- Weak organisational security culture

4.8.4 Implications for Artefact Design

These constraints directly shaped the artefact development approach:

- Artefacts are low-cost, simple, and practical
- Designed to work with existing tools (e.g., WhatsApp, manual logs)
- Focused on governance and process rather than technology

As a result, the artefacts are:

- Realistic to implement
- Scalable over time
- Suitable for incremental maturity development

4.9 Chapter Summary

This chapter presented the findings of the case study and identified significant gaps in cyber risk governance at DPMPTSP through a framework-based analysis aligned with ISO/IEC 27005 and NIST SP 800-39. The results indicate that governance maturity is predominantly at a nonexistent level, with only limited ad-hoc practices observed across risk identification and incident handling.

To address these gaps, a set of practical governance artefacts was developed, including a cyber risk governance roadmap, incident response flow, governance checklist, and a cyber risk register. These artefacts translate international framework principles into simplified and context-appropriate tools that can be realistically implemented within the organisation.

Client feedback further highlighted key constraints, including limited budget, lack of specialised expertise, and low organisational awareness, necessitating a pragmatic and incremental approach to governance improvement.

The next chapter discusses these findings in relation to existing literature and evaluates the proposed artefacts as mechanisms for improving cyber risk governance in resource-constrained public sector environments.

Chapter 5: Discussion and Governance Improvement Roadmap

5.1 Introduction

This chapter critically discusses the findings presented in Chapter 4 in relation to existing literature on cyber risk governance. It evaluates the identified governance gaps at DPMPTSP and examines how the developed artefacts address these gaps within the constraints of a resource-limited public sector environment.

Unlike descriptive discussions, this chapter adopts a critical perspective, assessing both the strengths and limitations of the proposed artefacts and exploring how they can be refined to improve governance effectiveness.

5.2 Interpretation of Findings in Relation to Literature

5.2.1 Absence of Formal Governance as an Empirical Finding

The findings reveal that DPMPTSP operates with minimal formal governance structures, consistent with literature showing that local governments and organisations in developing contexts often lack formalised cyber risk governance (Norris and Mateczun, 2025; Egwuatu, 2025).

This observation is consistent with the interview findings, which indicate that cyber governance practices are largely informal and lack organisational-level oversight.

The absence of policies, roles, and structured processes reflects what Magnusson et al. (2025) identify as governance failure rather than technical failure, where organisations lack the institutional mechanisms required to manage cyber risks systematically.

Critical Evaluation: Artefact Strategy

Rather than attempting full framework implementation, this study adopts an artefact-based approach, translating governance concepts into practical tools.

Strength

- Aligns with research emphasising context-sensitive governance for resource-constrained organisations
- Avoids “framework overload” (common failure in ISO/NIST adoption)

Limitation

- Artefacts may remain informal without organisational enforcement
- Governance improvement depends on management commitment, not artefact existence

Improvement

To strengthen this:

- Introduce minimum governance ownership (e.g. “risk coordinator role”)
- Embed artefacts into formal reporting cycles
- Link artefacts to management decision-making (not just documentation)

5.2.2 Cyber Risk Governance Roadmap (Critical Analysis)

As discussed in Chapter 4, the governance checklist adopts a selective mapping approach, focusing on key framework elements relevant to the organisation’s context and maturity level. In contrast, the proposed roadmap aligns with literature advocating phased and incremental implementation in public sector environments (Hossain et al., 2024), rather than immediate adoption of comprehensive frameworks. This reinforces the study’s emphasis on practical and context-sensitive governance improvement.

This is further supported by interview insights, which indicate that cyber security practices within the organisation are currently informal and resource-constrained, requiring gradual and structured improvement. Additionally, limited organisational awareness of cyber risk governance reinforces the need for an incremental and context-sensitive implementation approach.

Strengths

- Reflects real organisational constraints (budget and capability limitations)
- Prioritises governance foundations before technical controls
- Supports progressive maturity development

These strengths are consistent with research suggesting that governance maturity should be established prior to the implementation of advanced technical controls.

Limitations

- The roadmap assumes consistent execution over time, which may not occur
- No built-in performance measurement or KPI tracking
- Relies on internal motivation without enforcement

Improvement

To enhance effectiveness, the following improvements are recommended:

- Add simple KPIs (e.g. number of incidents recorded, percentage of reviewed risks)
- Establish periodic review checkpoints (e.g. quarterly governance reviews)
- Assign clear accountability for each phase

Without these enhancements, the roadmap risks remaining aspirational rather than fully actionable.

5.2.3 Incident Response Flow (Critical Analysis)

The incident response artefact directly addresses one of the most critical governance gaps: absence of structured incident handling.

Literature highlights that incident response is a foundational capability for organisational cyber resilience (KPMG, 2024).

Strengths

- Maintains existing communication practices - high usability
- Introduces minimal documentation - low resistance
- Enables organisational learning through incident logging

Limitations

- Lacks a formal severity classification model
- No integration with risk register or reporting mechanisms
- Relies heavily on individual administrator judgement

Improvement

- Introduce simple severity matrix (Low/Medium/High – clearly defined)
- Link incidents to risk register updates (closing the loop)
- Add post-incident review (even basic lessons learned)

Critical Insight

This artefact represents a shift from reactive handling to structured learning, but still requires integration into broader governance processes to be fully effective.

Beyond its operational role, the socialisation of the incident response process also functions as a behavioural mechanism for increasing awareness and engagement, reinforcing its importance not only as a technical control but as a driver of organisational culture.

5.2.4 Cyber Risk Register (Critical Analysis)

The cyber risk register is one of the most significant contributions of this study, aligning directly with ISO 27005 risk management principles.

Literature consistently identifies risk registers as core governance artefacts enabling visibility and prioritisation.

Strengths

- Introduces risk visibility (critical gap resolved)
- Uses simple qualitative scoring, therefore accessible to non-experts

- Aligns risks with actions and ownership

Limitations

- Risk assessment is subjective (qualitative only)
- No integration with strategic planning or budgeting
- May not be updated regularly (common failure in practice)

How It Can Be Improved

- Introduce periodic review cycle (e.g. every 6 months)
- Link risk levels to management actions (e.g. mandatory reporting for high risks)
- Gradually enhance with basic quantitative indicators (optional long-term)

Critical Insight

While simplified, the risk register effectively transforms the organisation from risk-unaware to risk-visible, which is a foundational governance improvement.

5.2.5 Governance Checklist (Critical Analysis)

The governance checklist functions as a bridge between theory (ISO/NIST) and practice (organisation).

This responds directly to literature highlighting that many organisations fail to operationalise framework requirements.

Strengths

- Provides structured maturity assessment
- Enables repeatable evaluation
- Aligns directly with internationally recognised frameworks

Limitations

- May become static if not regularly updated
- Requires interpretation to reduce the risk of inconsistent assessment
- Not yet fully operationalised into governance process

How It Can Be Improved

- Convert into periodic audit tool (annual or bi-annual)
- Assign ownership for completing checklist
- Link checklist results to roadmap updates

Placeholder Consideration

The finalised governance checklist will further enhance:

- Standardisation of assessment
- Traceability to ISO/NIST requirements
- Long-term governance monitoring

5.2.6 Cross-Cutting Constraint: Client Limitations

The evaluation of artefacts must be understood within the context of organisational constraints, which significantly influence implementation feasibility. These constraints were consistently highlighted in the interview, where the participant described limitations in resources, expertise, and organisational support.

Key Constraints Identified

- Limited budget (cannot implement full ISO/NIST controls)
- Limited IT workforce
- Lack of cybersecurity expertise
- Siloed system administration
- No structured awareness programme

Critical Interpretation

These constraints align with existing literature on public sector organisations in developing contexts, where governance maturity is often constrained by limited institutional capacity, cybersecurity practices remain reactive and fragmented, and framework adoption is restricted by resource availability.

Interview insights further reinforce this, indicating that cyber security activities are primarily operational and informal, with limited coordination across organisational functions and minimal strategic oversight.

Implications for Artefacts

Given these constraints, the developed artefacts are intentionally:

- Deliberately simplified
- Designed for low-cost implementation
- Focused on governance rather than technology

This ensures that the artefacts remain feasible and usable within the organisation's current capacity.

Key Risk

Despite this, even simplified artefacts may fail to achieve their intended impact if:

- Management support is weak
- Awareness remains low
- There is no accountability

What Should Be Prioritised

Based on findings, the organisation should prioritise:

1. Awareness and training
2. Role definition and accountability
3. Basic governance consistency

This emphasis on organisational and human factors aligns with literature suggesting that governance effectiveness is driven not only by technical controls, but by awareness, culture, and accountability mechanisms.

5.2.7 Benefits and Barriers to Adopting Cyber Risk Governance Frameworks

The findings of this study demonstrate that the adoption of structured cyber risk governance frameworks provides several organisational benefits, particularly in resource-constrained public sector environments.

Benefits of Adopting Structured Governance Mechanisms

The introduction of governance artefacts—such as the risk register, governance checklist, incident response flow, and roadmap—illustrates how structured approaches can enhance organisational clarity and accountability. These artefacts provide a common structure for identifying, assessing, and communicating cyber risks, enabling both technical and non-technical stakeholders to develop a shared understanding of risk.

This aligns with existing literature, which emphasises that governance frameworks serve as a common language for cyber risk management, bridging the gap between technical operations and managerial decision-making. Furthermore, the structured approach improves risk visibility, supporting more informed and proactive decision-making processes at the organisational level.

In the context of DPMPTSP, these benefits are particularly evident in the transition from informal, individual-based practices to more structured and documented governance mechanisms.

Barriers to Framework Adoption

Despite these benefits, the study also identifies several barriers to adopting cyber risk governance frameworks.

At an organisational level, limited financial resources and lack of specialised expertise restrict the ability to implement comprehensive frameworks such as ISO/IEC 27005 or NIST SP 800-39. These constraints are consistent with challenges commonly observed in public sector organisations within developing contexts.

Additionally, the absence of formal governance structures and limited strategic prioritisation of cyber security further hinder adoption efforts. Without management-level engagement, governance initiatives risk remaining operational rather than strategic.

Two Key Levels of Challenges

There are two key barriers identified in this study that I identified through the interview with the person-in-charge from DPMPTSP:

1. Usefulness and Willingness to Adapt

The findings suggest that there is limited organisational motivation to adopt structured governance practices, partly due to a lack of perceived value. In environments where cyber incidents have not resulted in significant disruption, cyber risk may be underestimated, leading to low prioritisation of governance initiatives.

This highlights the need to improve organisational awareness of the practical benefits of cyber risk governance, particularly in demonstrating how structured approaches support service continuity and risk reduction.

2. Knowledge and Capability Constraints

The study also identifies significant gaps in knowledge and capability.

Staff have limited familiarity with cyber risk governance concepts, frameworks, and best practices. In addition, technical expertise is concentrated within a small number of individuals, leading to siloed knowledge and limited organisational learning.

This reflects broader findings in the literature, which indicate that human and organisational factors—particularly awareness, training, and knowledge sharing—are critical determinants of governance effectiveness.

Addressing these challenges requires targeted capability development initiatives, including training programmes, awareness sessions, and incremental exposure to structured governance practices.

Implications

These findings reinforce the importance of adopting context-sensitive and incremental approaches to cyber risk governance. Rather than focusing solely on framework compliance, organisations must prioritise building foundational capabilities, enhancing awareness, and strengthening organisational commitment to governance practices.

5.2.8 Low-Resource Cyber Security Training Plan

Based on the findings of this study, one of the most critical barriers to effective cyber risk governance at DPMPTSP is the lack of organisational awareness, limited technical capability, and fragmented knowledge across system administrators. Addressing these challenges requires a structured training approach. However,

given the organisation's resource limitations, a traditional, resource-intensive training model is not feasible.

This study therefore proposes a low-resource cyber security training plan, designed to improve awareness, capability, and coordination without requiring significant financial or technical investment.

1. Conceptual Approach

The training plan is based on three principles:

1.1 Simplicity and Accessibility

Training content should be:

- Short (15–30 minutes per session)
- Easy to understand (non-technical language)
- Focused on practical scenarios

This aligns with research showing that usability and simplicity increase adoption of security practices, especially in organisations with low maturity.

1.2 Incremental Learning

Rather than one-time intensive training, learning should be:

- Delivered gradually (monthly or quarterly)
- Reinforced through repetition
- Integrated into daily practices

Literature on security awareness indicates that continuous reinforcement is more effective than one-off training.

1.3 Embedded in Existing Work Practices

Training should leverage:

- Existing meetings
- Existing communication tools (e.g., WhatsApp, email)
- Real incidents

This minimises cost and increases engagement.

2. Training Structure

The plan is structured into three progressive levels:

Level 1: Basic Awareness (All Staff)

Objective:

Increase general awareness of cyber risks

Topics:

- Phishing awareness
- Password best practices
- Safe use of email and systems
- Reporting incidents

Format:

- Short monthly sessions (15–30 minutes)
- Delivered via:
 - Internal meetings
 - Simple slides
 - Practical examples

Level 2: Operational Awareness (System Administrators)

Objective:

Improve technical and governance-related capability

Topics:

- Risk identification (linked to risk register)
- Incident response process (based on developed artefact)
- Basic patching and system monitoring
- Access control principles

Format:

- Quarterly sessions
- Case-based discussion (real incidents)
- Demonstration using artefacts

Level 3: Governance Awareness (Management)

Objective:

Improve strategic understanding and decision-making

Topics:

- Importance of cyber risk governance
- Risk reporting and prioritisation
- Use of artefacts (dashboard, risk register)
- Role of management in governance

Format:

- Brief quarterly briefing (20–30 minutes)
- Focus on decision-making, not technical details

3. Delivery Method (Low-Resource)

The plan uses existing organisational tools only, including:

- Microsoft Teams (video calls)
- Email (sharing materials)

- WhatsApp (quick reminders)
- Google Drive (document repository)

No additional software or paid platforms required.

4. Integration with Developed Artefacts

The training plan is directly aligned with the governance artefacts developed in this study:

Artefact	Training Integration
Risk Register	Used in training to explain risk identification
Incident Response Flow	Demonstrated during awareness sessions
Governance Checklist	Used to explain governance maturity
Roadmap	Supports long-term capability building

Table 5.1 Training Integration with Artefact

This ensures training is practical, not theoretical.

5. Expected Outcomes

The implementation of this training plan is expected to:

- Improve awareness of cyber risks across staff
- Enhance technical and governance capability of IT personnel
- Reduce reliance on individual knowledge (siloed working)
- Support consistent use of governance artefacts
- Strengthen organisational cyber risk culture

6. Limitations and Considerations

While the plan is designed to be practical, several limitations exist:

- Participation may be inconsistent without management enforcement
- Knowledge improvements may be gradual rather than immediate
- Requires ongoing commitment despite low cost

These limitations reinforce that training effectiveness depends on organisational culture and leadership support.

Training Plan Considerations

The development of the proposed low-resource cyber security training plan is grounded in the operational constraints identified within the organisation, particularly limited financial resources and staffing capacity. These constraints

significantly restrict the feasibility of adopting conventional training approaches, such as external certifications or specialised cybersecurity programmes.

To address this, the training plan emphasises the use of existing organisational structures, roles, and communication mechanisms, rather than reliance on external resources. Training activities are embedded within routine practices, including internal meetings, system administration tasks, and incident handling processes. This approach ensures that capability development can be achieved with minimal additional cost while maintaining relevance to daily operations.

Furthermore, the design of the training plan acknowledges that effective cyber security awareness must be reinforced over time. Consistent with existing literature, the study recognises that continuous and context-based training approaches are more effective than one-off interventions, particularly in organisations with low governance maturity.

Finally, the training concept is informed by an ongoing effort to align practical interventions with academic and professional best practices. This ensures that the proposed approach is not only feasible within the organisational context but also grounded in established principles of cyber risk governance and organisational learning.

Socialisation of Incident Management as a Behavioural Driver

An important insight emerging from the study is the role of incident management socialisation as a practical mechanism for driving behavioural change and improving organisational engagement with cyber risk governance.

Rather than relying solely on formal training, the dissemination and regular discussion of the incident handling and escalation process were identified as an effective way to build organisational awareness and participation. This includes explaining how incidents should be reported, escalated, and documented, as well as clarifying the roles of different stakeholders in the process.

This approach supports the development of a shared understanding of cyber risk responsibilities, enabling staff to actively participate in governance practices. It also serves as an entry point for increasing organisational buy-in, particularly in environments where awareness of cyber risk is limited.

From a behavioural perspective, this aligns with research on security culture, which suggests that practical and experience-based learning mechanisms are more effective in influencing behaviour than purely theoretical training. By engaging staff in real or simulated incident scenarios, the organisation can gradually shift from reactive behaviour to more structured and proactive practices.

Importantly, incident management socialisation also addresses previously identified issues of siloed working. By introducing a shared process, it promotes coordination and communication across roles, contributing to improved organisational resilience.

As a result, incident management socialisation is incorporated as a key early initiative within Phase 1 of the governance roadmap, supporting initial awareness, behavioural change, and adoption of governance artefacts.

5.3 Conclusion

The findings and artefacts collectively demonstrate that cyber risk governance in resource-constrained public sector organisations cannot rely on direct or full adoption of comprehensive frameworks such as ISO/IEC 27005 or NIST SP 800-39.

Instead, governance must be developed incrementally through context-adapted artefacts that prioritise simplicity, usability, and organisational fit. The artefacts developed in this study—including the governance roadmap, incident response flow, cyber risk register, and governance checklist—translate international governance principles into practical and implementable mechanisms tailored to the organisation's operational realities.

However, the critical analysis shows that the effectiveness of these artefacts depends not solely on their design, but on their integration into organisational processes, management oversight, and accountability structures. Without such integration, there is a risk that artefacts remain informal and underutilised.

These findings reinforce the argument that cyber risk governance maturity is primarily an organisational and cultural challenge, rather than a purely technical or framework-driven issue.

5.4 Practical Contribution of the Study

This study contributes practical value by demonstrating that meaningful improvements in cyber risk governance can be achieved without extensive financial or technical investment. By focusing on governance fundamentals rather than advanced technical controls, the study provides a realistic and applicable approach for local public sector organisations operating under resource constraints.

A key contribution lies in the development of artefact-based governance mechanisms, which operationalise abstract framework principles into concrete tools that can be directly applied within the organisation. These artefacts enable gradual governance improvement by enhancing risk visibility, supporting structured incident handling, and introducing basic accountability and monitoring practices.

In contrast to traditional approaches that emphasise full framework adoption, this study highlights the effectiveness of incremental and context-sensitive implementation, particularly in developing country contexts where institutional capacity is limited.

Furthermore, the findings emphasise that recognising governance absence as a critical risk factor is essential. Organisations must prioritise foundational governance capabilities—such as role definition, awareness, and basic risk documentation—before pursuing advanced controls, certifications, or technical solutions.

5.5 Chapter Summary

This chapter critically examined the findings of the case study in relation to existing literature and evaluated the effectiveness of the developed governance artefacts. It demonstrated that cyber risk governance within DPMPTSP is characterised by structural, process, and cultural deficiencies, consistent with challenges identified in resource-constrained public sector environments.

Through critical analysis, the chapter showed how the developed artefacts address these governance gaps while also identifying their limitations and areas for improvement, particularly in relation to organisational adoption, accountability, and sustainability.

The discussion further highlighted the significance of organisational constraints—including limited resources, skills gaps, and low awareness—in shaping both governance practices and the feasibility of improvement initiatives.

The next chapter concludes the study by summarising its overall contributions, reflecting on limitations, and outlining directions for future research.

Chapter 6: Conclusion and Recommendations

6.1 Introduction

This chapter concludes the dissertation by summarising the research, revisiting the research objectives, and reflecting on the key findings and contributions. It also discusses the limitations of the study and proposes directions for future research.

Building on the findings and critical discussion presented in previous chapters, this chapter highlights how cyber risk governance challenges in resource-constrained public sector organisations can be addressed through practical, context-adapted governance mechanisms.

6.2 Summary of the Research

This study examined the state of cyber risk governance within a local public sector organisation, DPMPTSP Cilacap, through an in-depth qualitative case study. The research aimed to assess current governance practices, identify gaps when benchmarked against international frameworks, and develop practical improvement mechanisms suitable for a resource-constrained environment.

A qualitative methodology was employed, combining semi-structured interviews with document review and artefact analysis. The absence of governance artefacts—such as policies, structured risk management processes, and incident response procedures—was treated as empirical evidence and validated through practitioner insights.

A framework-based gap analysis aligned with ISO/IEC 27001, ISO/IEC 27005 and NIST SP 800-39 demonstrated that governance maturity is largely nonexistent, with only limited ad-hoc practices observed.

To address these gaps, the study developed a set of practical governance artefacts, including a cyber risk governance roadmap, incident response flow, cyber risk register, and governance checklist. These artefacts were designed to translate international governance principles into simplified and implementable tools tailored to the organisation's operational constraints.

6.3 Achievement of Research Objectives

The research objectives set out in Chapter 1 have been achieved as follows:

1. Assessment of current cyber risk governance practices
The study identified that cyber risk governance at DPMPTSP is largely informal, reactive, and concentrated within a single IT role, with limited organisational oversight or accountability.

2. Identification of governance gaps against international standards
Significant misalignment was identified between organisational practices and the expectations of ISO/IEC 27005 and NIST frameworks, particularly in relation to risk identification, assessment, documentation, and monitoring processes.
3. Examination of organisational and human factors
The findings demonstrated that governance weaknesses are strongly influenced by organisational constraints, including limited resources, lack of specialised expertise, and low levels of awareness, confirming that cyber risk governance is primarily an organisational challenge rather than a purely technical issue.
4. Development of practical improvement mechanisms
The study proposed and developed a set of artefact-based governance solutions, enabling incremental improvement of governance maturity without requiring full framework implementation.

6.4 Key Contributions of the Study

This study makes contributions to both academic research and practice.

From an academic perspective, it contributes to the limited body of empirical research on cyber risk governance at the local public sector level in developing country contexts. By focusing on governance absence as an empirical condition, the study provides insight into how cyber risk is managed in environments where formal structures are largely unavailable.

From a practical perspective, the study introduces an artefact-based approach to cyber risk governance, demonstrating how abstract framework principles can be operationalised into simple, usable tools. This approach provides a viable alternative to traditional framework adoption, which is often impractical for resource-constrained organisations.

Importantly, the study highlights that governance maturity is achieved not through compliance alone, but through the integration of governance practices into organisational processes, accountability structures, and culture.

6.5 Limitations of the Study

Despite its contributions, this study has several limitations.

First, the research is based on a single case study, limiting the generalisability of the findings. While the results provide analytically transferable insights, they may not fully represent conditions in larger or better-resourced public sector organisations.

Second, data collection relied on a single primary informant due to the organisational structure. Although this reflects the operational reality, it limits the diversity of perspectives and may introduce bias.

Third, the study focuses primarily on governance structures and processes rather than technical controls, and therefore does not assess the effectiveness of specific cybersecurity technologies.

Finally, while the proposed artefacts provide practical governance mechanisms, their effectiveness has not been evaluated through long-term implementation. As discussed in Chapter 5, their success depends significantly on organisational adoption, management support, and ongoing maintenance.

6.6 Recommendations for Future Research

Future research could extend this study in several directions.

First, comparative case studies across multiple public sector organisations could provide broader insights into governance patterns and contextual differences.

Second, longitudinal research could evaluate the effectiveness of artefact-based governance approaches over time, particularly in improving organisational resilience and governance maturity.

Third, future studies could integrate technical and governance perspectives by combining risk governance analysis with system-level security assessments.

Finally, research could explore the role of national policy frameworks and inter-organisational collaboration in supporting local-level cyber risk governance, particularly in developing country contexts.

6.7 Final Conclusion

This dissertation has demonstrated that cyber risk governance at DPMPTSP Cilacap is characterised by the absence of formal structures, processes, and documentation, resulting in a reactive and fragmented approach to managing cyber risks.

Through a qualitative case study and framework-based analysis, the study has shown that governance absence itself constitutes a critical organisational vulnerability.

By developing and evaluating a set of practical governance artefacts, the research demonstrates that meaningful improvements in cyber risk governance can be achieved through incremental, context-sensitive approaches, rather than through immediate adoption of comprehensive international frameworks.

Ultimately, the study reinforces the argument that cyber risk governance is not solely a technical challenge, but fundamentally an organisational and cultural one. Sustainable improvement therefore requires not only tools and frameworks, but also

integration into organisational practices, accountability structures, and continuous learning processes.

References

- Egwuatu, O.V. (2025) 'Cybersecurity readiness in developing countries' enterprises: A comparative multi-case analysis', *Magna Scientia Advanced Research and Reviews*, 15(1), pp. 68–83. Available at: <https://magnascientiapub.com/journals/msarr/sites/default/files/MSARR-2025-0110.pdf> (Accessed: 18 May 2026).
- Folorunso, A., Mohammed, V., Wada, I. and Samuel, B. (2024) 'The impact of ISO security standards on enhancing cybersecurity posture in organizations', *World Journal of Advanced Research and Reviews*, 24(1), pp. 2582–2595. Available at: https://wjarr.com/sites/default/files/fulltext_pdf/WJARR-2024-3169.pdf (Accessed: 18 May 2026).
- Hossain, S.T., Yigitcanlar, T., Nguyen, K. and Xu, Y. (2024) 'Local government cybersecurity landscape: A systematic review and conceptual framework', *Applied Sciences*, 14(13), p. 5501. Available at: <https://www.mdpi.com/2076-3417/14/13/5501>
- Hossain, S.T., Yigitcanlar, T., Nguyen, K. and Xu, Y. (2025) 'Cybersecurity in local governments: A systematic review and framework of key challenges', *Urban Governance*, 5(1), pp. 1–19. Available at: <https://eprints.qut.edu.au/254687/> (Accessed: 18 May 2026).
- ISACA (2024) 'Cybersecurity risk management governance: An agency theory perspective', *ISACA Journal*, Volume 5. Available at: <https://www.isaca.org/resources/isaca-journal/issues/2024/volume-5/cybersecurity-risk-management-governance> (Accessed: 18 May 2026).
- Kayode-Ajala, O. (2023) 'Establishing cyber resilience in developing countries: An exploratory investigation into institutional, legal, financial, and social challenges', *International Journal of Sustainable Infrastructure for Cities and Societies*, 8(9), pp. 1–10. Available at: <https://vectoral.org/index.php/IJSICS/article/view/27> (Accessed: 18 May 2026).
- KPMG (2024) 'Cybersecurity considerations: government and public sector'. Available at: <https://kpmg.com/xx/en/our-insights/ai-and-technology/cybersecurity-considerations-2024-government-and-public-sector.html> (Accessed: 18 May 2026).
- Magnusson, L., Iqbal, S., Elm, P. and Dalipi, F. (2025) 'Information security governance in the public sector: Investigations, approaches, measures, and trends', *Computers & Security*. Available at: <https://link.springer.com/article/10.1007/s10207-025-01097-x> (Accessed: 18 May 2026).
- Norris, D.F. and Mateczun, L.K. (2023) 'Adoption of cybersecurity policies by local governments', *Journal of Cybersecurity Education, Research and Practice*, 2023(2).

Available at: <https://digitalcommons.kennesaw.edu/jcerp/vol2023/iss2/9/> (Accessed: 18 May 2026).

Norris, D.F. and Mateczun, L.K. (2025) 'Managing cybersecurity in local governments: 2022', *Journal of Cybersecurity Education, Research and Practice*, 2025(1). Available at: <https://digitalcommons.kennesaw.edu/jcerp/vol2025/iss1/2/> (Accessed: 18 May 2026).

World Bank (2025) 'Enhancing cyber resilience in developing countries'. Available at: <https://www.worldbank.org/en/results/2025/01/29/-enhancing-cyber-resilience-in-developing-countries> (Accessed: 18 May 2026).

Appendix

This appendix presents selected extracts of the governance checklist utilised in this study. Only partial excerpts are included to maintain readability and ensure confidentiality. The complete version of the checklist is provided separately.

Appendices A–E contain the artefacts developed throughout the dissertation process, while Appendices F–J comprise supporting evidence obtained from DPMPTSP, which informed the gap analysis. Refer to Appendix K for the GitHub Link.

Appendix A (DPMPTSP_Governance_Checklist_Gap Analysis)

Checklist Item	ISO/IEC 27001 Clause	ISO/IEC 27005 Activity	NIST SP 800-39	Evidence Available (Yes/Partial/No)	Existing DPMPTSP Evidence	Notes / Gap Identified
Defined cyber/IT risk roles and responsibilities	5.3, 5.4	Context Establishment	Risk Governance	Partial	Struktur Organisasi DPMPTSP	No specific cyber risk ownership
Cyber risk reporting to management/committee	5.1	Risk Communication	Senior Leadership Oversight	No	None	No formal report
Risk management policy exists	6.1	Risk Identification	Risk Framing	Yes	Kebijakan Manajemen Risiko (umum)	Not Specifically for IT/Cybersecurity
IT / Cyber risk management procedure	6.1	Risk Analysis	Risk Assessment	No	None	Do Not Exist

Appendix B (DPMPTSP_Cyber_Risk_Governance_Roadmap_EN)

Cyber Risk Governance Roadmap (Phased Implementation)

DPMPTSP – A Practical and Incremental Improvement Plan

1. Roadmap Objective

This roadmap provides a phased and realistic plan to strengthen cyber risk governance at DPMPTSP. It is developed based on the current (AS-IS) condition and focuses on incremental improvements that can be implemented within the public sector environment, [taking into account](#) limited resources.

2. Guiding Principles

The following principles form the foundation for developing this roadmap, ensuring that improvements to cyber risk governance are realistic, gradual, and aligned with DPMPTSP's current conditions and capacity:

- Starting from existing practices and strengthening them incrementally.
- Prioritizing governance, roles, and documentation before technical controls.
- Avoiding excessive bureaucracy or the use of complex tools.
- Aligning improvements with the principles of ISO/IEC 27005, ISO/IEC 27001, and NIST SP 800-39.

3. Cyber Risk Governance Roadmap

A phased Cyber Risk Governance Roadmap was developed to provide a structured and realistic approach to improving governance practices within DPMPTSP. The roadmap is designed to reflect the organisation's current constraints while enabling incremental and sustainable maturity development.

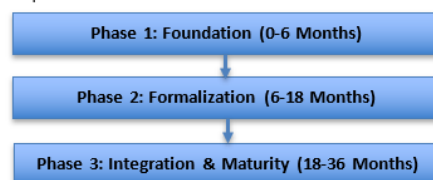


Figure1. Cyber Risk Improvement Roadmap

Appendix C (DPMPTSP_Incident_Response_Flow_ASIS_TOBE_EN)

Incident Response & Escalation Flow

Purpose

This document provides a simple incident response and escalation flow for cyber security incidents at DPMPTSP. It is designed to reflect the current governance condition and can be applied without requiring specialized technical tools.

Scope

- Information security incidents
- System or application service disruptions
- Suspicious emails or phishing attempts
- Data leakage or data loss

Based on the scope of incidents above, particularly those involving data leakage or data loss, it is important for DPMPTSP to have a clear understanding of how incidents are currently handled. Therefore, this document first describes the existing incident response practices (AS-IS) as they are currently applied, which then serve as a baseline for proposing gradual and realistic improvements (TO-BE).

A. AS-IS: Current Incident Response Flow

This section documents the current cyber incident response flow in DPMPTSP. The process is informal and relies primarily on direct communication. Figure 1 illustrates the current incident response and escalation process, outlining the step-by-step procedures for handling cyber incidents within the organisation.

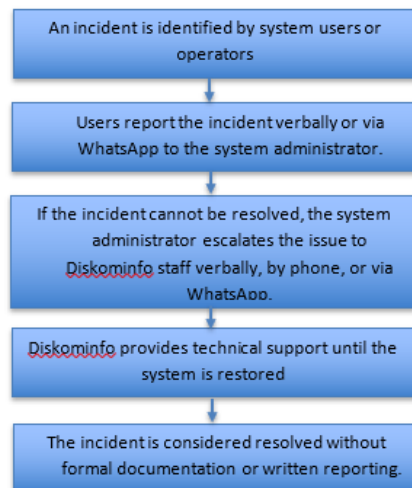


Figure 1. As-is incident response and escalation process

Appendix D (DPMPTSP_Top10_Cyber_Risk_Register_with_Guidance)

Purpose This tab presents the Top 10 prioritized cyber risks identified for the organization based on their potential impact and likelihood. It is intended to support management awareness, decision-making, and risk treatment planning.										
Scope The risks listed reflect key information systems, services, and processes that are considered critical to organizational operations and public service delivery. The focus is on risks that may significantly affect confidentiality, integrity, availability, and public trust.										
Methodology Risks are assessed using qualitative ratings (Low / Medium / High) supported by numerical scoring. Overall risk level is determined based on the Risk Rating Guidance tab. This register represents a living document and is reviewed periodically or following significant incidents or changes.										
Usage High risks require priority mitigation and management reporting. Medium risks require planned mitigation and monitoring. Low risks are monitored and managed through routine controls.										
Document Information Document Name: Top 10 Cyber Risk Register Organization / Unit: (e.g., DPMPTSP) Prepared By: (Name / Role) Reviewed By: (Optional – Management / IT Head) Creation Date: (YYYY-MM) Last Updated: (YYYY-MM) Next Review Due: (YYYY-MM)										
Risk ID	Asset / Process	Risk Description	Threat Source	Vulnerability	Impact	Likelihood	Overall Risk	Existing Controls	Risk Owner	Risk Treatment
R-001	Online Licensing	Unauthorized access resulting in applicant data leakage	Cyber attack / human error	Weak access controls	High	Medium	High	Password login	Head of IT Subdivision	Mitigate
R-002	Public Website	Service disruption due to DDoS attack	External attack	No monitoring in place	Medium	Medium	Medium	Hosting provider	Website Administrator	Mitigate
R-003	Internal Email	Phishing attack leading to account compromise	External attack	Low user awareness	High	High	High	Antivirus	Head of IT Subdivision	Mitigate
R-004	Application Server	Malware infection	Cyber attack	Irregular patching	High	Medium	High	Antivirus	IT Unit	Mitigate

Appendix E (DPMPTSP_Governance_Checklist for DPMPTSP)

PURPOSE

This checklist assesses the current state of cyber risk governance at DPMPTSP by mapping existing practices against ISO/IEC 27001, ISO/IEC 27005, and NIST SP 800-39.

MAPPING METHODOLOGY

Each item is rated based on evidence availability (Yes / Partial / No). 'Partial' indicates existing but informal or inconsistent practices.

HOW TO USE

Step 1: Review each checklist item
Step 2: Check if evidence exists
Step 3: Assign status:
Yes = fully implemented and documented
Partial = informal or inconsistent
No = not implemented
Step 4: Score is automatically calculated
Step 5: Review maturity percentage

SCORING EXPLANATION

Score Meaning:
2 = Defined (formal and consistent)
1 = Ad-hoc (informal or incomplete)
0 = Non-existent

IMPORTANT NOTE

This tool is intended for internal self-assessment and continuous improvement.
It should be updated periodically (e.g., every 6 months).

< >

Governance Checklist

Dashboard

Checklist Tata Kelola

Dashboard-Bahasa Indone ...

+

:

IMPORTANT NOTE
This tool is intended for internal self-assessment and continuous improvement.
It should be updated periodically (e.g., every 6 months).

Domain	Checklist Item	ISO/IEC 27001 Clause	ISO/IEC 27005 Activity	NIST SP 800-39	Evidence Available (Yes/Partial/No)	Score	Existing DPA
Governance & Leadership	Defined cyber/IT risk roles and responsibilities	5.3, 5.4	Context Establishment	Risk Governance	Partial	1	Struktur Organisasi
Governance & Leadership	Cyber risk reporting to management/committee	5.1	Risk Communication	Senior Leadership Oversight	Partial	1	
Risk Management	Risk management policy exists	6.1	Risk Identification	Risk Framing	Yes	2	Kebijakan Manajem
Risk Management	IT / Cyber risk management procedure	6.1	Risk Analysis	Risk Assessment	Partial	1	
Risk Management	Maintained risk register	8.2	Risk Analysis	Risk Assessment	Yes	2	Risk Register / Risk I
Policies & Procedures	IT management policies & SOPs (access, change, backup)	8.1	Risk Treatment	Risk Response	Partial	1	
Policies & Procedures	Cyber security policy & SOP	5.2	Risk Treatment	Risk Response	No	0	
Awareness & Culture	Cyber security awareness training conducted	7.2	Risk Communication	Org-wide Awareness	Partial	1	Bukti Pelatihan Awa
Incident Management	Incident response & escalation procedure	8.4	Risk Monitoring	Risk Monitoring	Partial	1	

< >

Governance Checklist

Dashboard

Checklist Tata Kelola

Dashboard-Bahasa Indone ...

+

:

Maturity level Interpretation:

0–30% = Low (Non-existent)
31–60% = Emerging (Ad-hoc)
61–100% = Defined governance

Total Score:

13

Maximum Score:

28

Maturity%:

46.43 %

< >

Governance Checklist

Dashboard

Checklist Tata Kelola

Dashboard-Bahasa Indone ...

+

:

J. DINAS PENANAMAN MODAL DAN PELAYANAN TERPADU SATU PINTU

```
graph TD
    KD[KEPALA DINAS] --- KJF1[KELOMPOK JABATAN FUNGSIONAL]
    KD --- SEK[SEKRETARIAT]
    KD --- BPPM[BIDANG PENGEMBANGAN PENANAMAN MODAL]
    KD --- BPPM2[BIDANG PROMOSI PENANAMAN MODAL]
    KD --- BPPN[BIDANG PELAYANAN PERIZINAN DAN NON PERIZINAN]
    KD --- BP[BIDANG PENGENDALIAN]
    SEK --- SBKA[SUBBAGIAN KEUANGAN DAN ASET]
    SEK --- SBKU[SUBBAGIAN UMUM DAN KEPEGAWAIAN]
    SEK --- KJF2[KELOMPOK JABATAN FUNGSIONAL]
    BPPM --- KJF3[KELOMPOK JABATAN FUNGSIONAL]
    BPPM2 --- KJF4[KELOMPOK JABATAN FUNGSIONAL]
    BPPN --- KJF5[KELOMPOK JABATAN FUNGSIONAL]
    BP --- KJF6[KELOMPOK JABATAN FUNGSIONAL]
```

[illegible]

Appendix H (Risk Register Umum/ Daftar Risiko Umum)

PENETAPAN KONTEKS RISIKO STRATEGIS OPD

Nama Pemerintah Daerah :	Pemerintah Kabupaten Cilacap
Tahun Penilaian :	2026
Periode yang dinilai :	2025-2029
Urusan Pemerintahan :	1. Urusan Pemerintahan Wajib yang tidak berkaitan dengan Pelayanan Dasar Bidang Penanaman Modal
OPD yang Dinilai :	Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu
Sumber Data :	Renstra 2025-2029
Tujuan Strategis :	Meningkatnya Realisasi Investasi di Kabupaten Cilacap
Sasaran Strategis :	1. Meningkatnya Investasi Baru di Kabupaten Cilacap 2. Meningkatnya Kualitas Pelayanan Publik

Appendix I (Bukti Pelatihan Awareness (Ad-hoc))

INSIDE THE HACKER'S MIND

Mengungkap Cara Hacker Mengambil Data Kita



MATERI

01 UU Perlindungan Data Pribadi

03 Pemasangan Plugin Wordfence

Appendix J (Compliance Certification to ISO9001/Dokumen kepatuhan ISO9001)

This is to certify that:

Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu Kabupaten Cilacap

Jl. Dr. Soetomo No.02 Cilacap, Jawa Tengah INDONESIA

operates a

QUALITY MANAGEMENT SYSTEM

which complies with the requirements of

ISO 9001:2015

for the following scope

Provision of local government service in Kabupaten Cilacap for issuance of licenses and investment permit.

Certificate Number:

QEC29545

Originally Certified:

2 January 2012

Current Certification:

30 November 2023

Issue Date:

30 November 2023

Expiry Date:

1 January 2027





Calin Moldovean

President, Business Assurance

SAI Global Certification Services Pty. Ltd.
Level 7 Suite 7.01 45 Clarence Street
Sydney NSW 2000
Australia

Registered by:

SAI Global Certification Services Pty Ltd (ACN 108 716 669) Level 7 Suite 7.01 45 Clarence Street Sydney NSW 2000 Australia with PT SAI Global Indonesia Graha Iskandarsyah 4th fl Jl. Iskandarsyah Raya No. 66 C Kebayoran Baru Jakarta 12160 Indonesia ("SAI Global") and subject to the SAI Global Terms and Conditions for Certification. While all due care and skill was exercised in carrying out this assessment, SAI Global accepts responsibility only for proven negligence. This certificate remains the property of SAI Global and must be returned to SAI Global upon its request. To verify that this certificate is current please refer to SAI Global On-Line Certification register at <http://register.saiglobal.com/>



Appendix K – GitHub

<https://github.com/starspace-lab/Dissertation-Fiqki-A>

